



TOPIC PROPOSAL

Governing the AI nobody approved, and nobody logged.

An agentic AI system that discovers which AI tools an organisation is actually using, reads each vendor's terms, verifies its own findings, and keeps watching for changes.

5 agents

autonomous, each with one job

8

governance questions per tool

14 weeks

research, build, validate

0

live systems accessed

SUBMITTED BY

Manishkumar Yadav

250104002031

MBA · CYBER SECURITY MANAGEMENT





Sixty résumés went into ChatGPT and nobody in the company knows it happened.

An HR executive at a 200-person pharmaceutical firm had one vacancy and sixty applications. She uploaded all sixty and asked for a ranking. It saved her four hours.

Sixty people's names, addresses and salary histories left the organisation. None of them consented. No log records it. She broke no rule, because **no rule existed**.

60

data principals
affected, unaware

0

consent records
or audit entries

₹250 cr

maximum penalty
under the DPDP Act

HR EXECUTIVE · 11:04

I've got 60 CVs for one role. Going to paste them into ChatGPT and ask it to rank them — saves me the afternoon.

NOBODY, AT ANY POINT

Is that allowed? Where does the data go? Do they train on it?

IT, THREE MONTHS LATER

Which AI tools do we use? I genuinely don't know. Nobody has ever made a list.



The governance failure is not the upload. It is that the organisation has no way to know it occurred.

“Shadow AI”. Three properties that make it ungovernable.

Employees using AI tools for work without approval, oversight or record. Not malicious — the tools genuinely help. The failure is organisational, not behavioural.



01

It arrived bottom-up

Adoption reached hundreds of millions of users in roughly two years — employee by employee, never through IT procurement. No approval was ever sought because no approval process existed.

Consequence: the asset register was never updated, because nobody bought an asset.



02

It leaves almost no trace

Opening a website is not an installation. No software to detect, no licence to audit, no purchase order to find. Existing controls — antivirus, software audit, asset management — see nothing.

Consequence: discovery has to be inferred from network and sign-in data, not from an inventory.



03

The risk changes silently

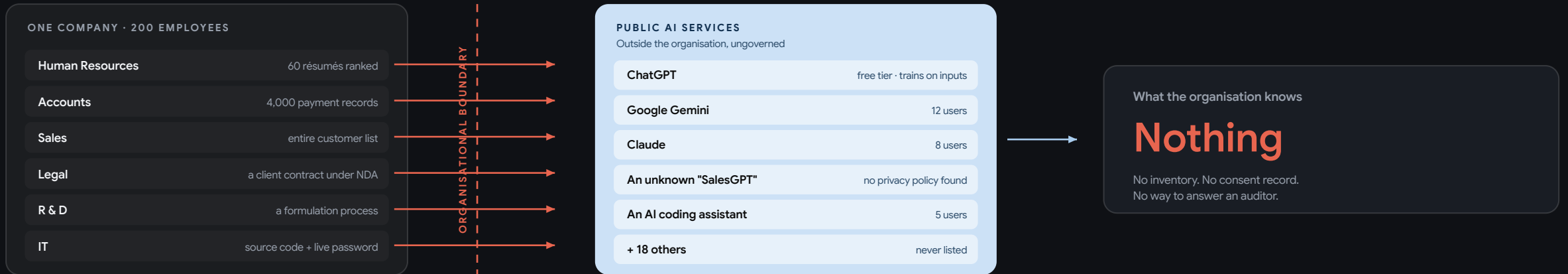
AI vendors revise privacy terms frequently and without notice. A tool assessed as safe in one quarter can become unsafe in the next, with no notification to the organisation.

Consequence: a one-off assessment is obsolete almost immediately. This is the gap the project targets.



One company. One week. Six departments.

Each of these is a documented pattern of workplace AI use. None of the six people believed they were doing anything wrong.



Personal data

60 résumés · 4,000 customer records

Confidential

a client contract under NDA

Trade secret

a formulation process

Credentials

source code containing a live password



Four functions. None of them owns this.

Each is waiting for another to act, and each is waiting for information nobody is producing. **Producing that information is what this project builds.**

IT Department

Sees a policy matter, not a technical one.
Nothing to patch, no software to remove.

→ refers it to Legal

Legal & Compliance

Cannot assess risk without knowing which tools are in use. Needs the inventory that does not exist.

→ refers it back to IT

Human Resources

Could issue guidance, but has no basis for deciding which tools are acceptable.

→ waits for a policy

Senior Management

Unaware there is a decision to make until a customer, auditor or regulator raises it.

→ finds out last



Three bodies of law now depend on an inventory that does not exist

The **DPDP Act 2023** requires a lawful basis and safeguards for personal data. **GDPR** flows down through export contracts. The **EU AI Act** adds transparency and documentation duties. Each assumes the organisation knows what it processes, where, and by whom.

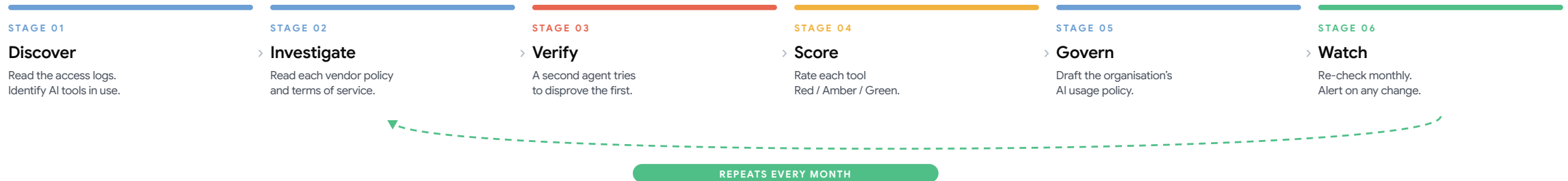
WHY EXISTING CONTROLS MISS IT

Antivirus	no file to scan
Software audit	no licence to find
Firewall log	site visited, content unknown
Awareness training	produces no inventory
Blocking everything	moves usage to personal phones



A web application where agents do the investigating.

Six stages. The first five run at setup; the sixth runs on a schedule forever and feeds its findings back into stage two. **That loop is the contribution.**



NOT A FIXED LIST

A database of twenty known tools is obsolete in weeks. When the agent meets a domain it does not recognise, it **fetches the site and decides for itself** whether it is an AI service.

NOT A CHATBOT ANSWER

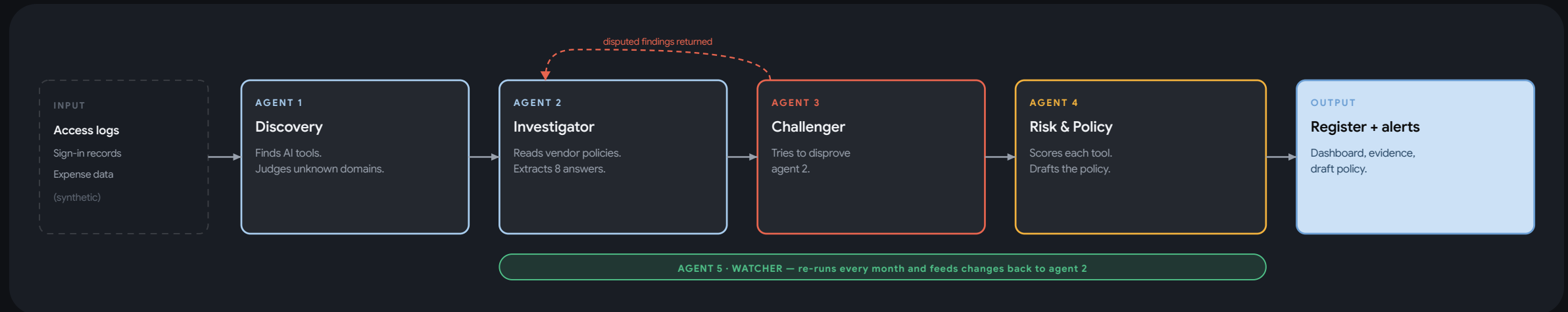
Every finding must quote the clause it came from, with the date it was read. Anything that cannot be corroborated is published as **“Not Verified”** rather than asserted.

NOT A ONE-OFF REPORT

The Watcher re-reads every vendor's terms monthly and diffs them against the stored version. **No human will re-read 23 privacy policies every month.** An agent will.



Five agents. One of them exists only to disagree.



1 · Discovery

Tools

Log parser · web fetch · domain lookup

Produces

A list of tools in use, with user counts

Reads logs, finds AI tools, judges unknown domains by fetching them.



2 · Investigator

Tools

Web fetch · document parser · citation store

Produces

Eight answers per tool, each with a clause

Reads each vendor's policy and terms, extracts the eight answers with citations.



3 · Challenger

Tools

Source re-fetch · claim comparison

Produces

Confirmed / Disputed / Not Verified

Tries to disprove agent 2. Marks anything uncorroborated as Not Verified.



4 · Risk & Policy

Tools

Scoring model · policy template

Produces

Red-Amber-Green rating and a draft policy

Scores each tool Red / Amber / Green and drafts the AI usage policy.



5 · Watcher

Tools

Scheduler · stored history · text diff

Produces

Change alerts with old and new text

Runs monthly, diffs every policy against last month, alerts on change.

“How is this not just ChatGPT?”

The question I expect first in the viva. Five standard properties distinguish an autonomous agent from a single model call — the design satisfies all five.

OPTION A

A list of known tools

Finds unknown tools **No**

Stays current **No**

Verifies itself **No**

Obsolete in weeks, blind to the long tail where the real risk sits.

OPTION B

Ask a language model

Finds unknown tools **No**

Stays current **No**

Verifies itself **No**

Answers from training data, with no source and no way to separate fact from invention.

THIS PROJECT

A multi-agent system

Finds unknown tools **Yes**

Stays current **Yes**

Verifies itself **Yes**

The work is unbounded, repetitive and never finished — the shape of problem an agent suits.

THE FIVE PROPERTIES, AND WHERE EACH APPEARS

01

A loop

Plan, act, observe, repeat

Agents 1–3 re-run until every tool has eight verified answers

02

Tool use

It calls real tools, not memory

Web fetch, document parser, log reader, database, scheduler

03

Memory

It remembers and notices change

Every finding stored with its source and the date read

04

Multiple roles

Agents check each other

Agent 3 exists only to disprove agent 2

05

Termination

It knows when to escalate

Unverifiable findings escalate instead of being guessed

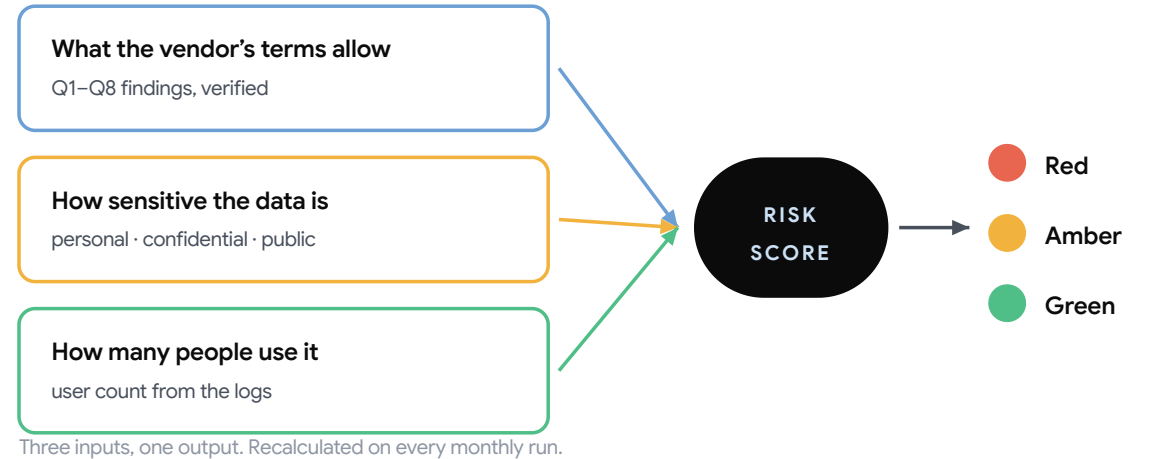


Eight questions, asked of every vendor.

Designing this list is the intellectual work of the project: it determines what the agents look for and what the risk rating means. It is my own framework, and it is usable independently of the software.

- **Q1** Do they train on our inputs?
- **Q2** Can that be switched off, on which plan?
- **Q3** How long is data retained?
- **Q4** In which country are the servers?
- **Q5** Will they sign a DPA?
- **Q6** Any recognised certification?
- **Q7** Do they share with sub-processors?
- **Q8** Can we compel deletion?

HOW THE RATING IS CALCULATED

**Red**

Prohibit or replace

Amber

Restrict and monitor

Green

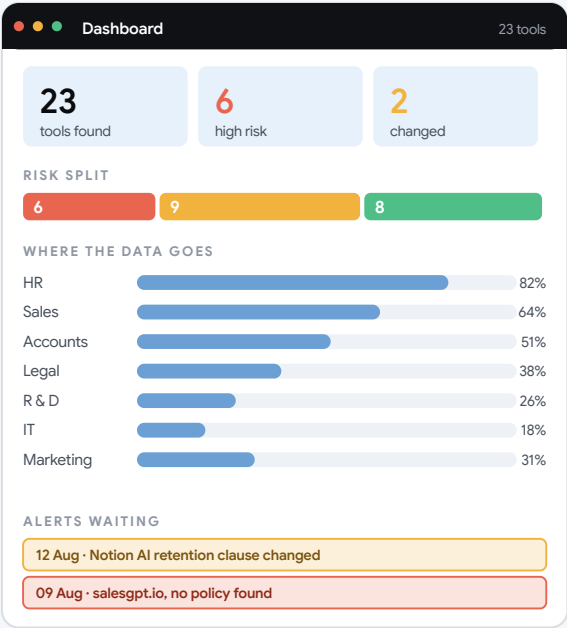
Approve for use

A deliberate design choice. A tool used by three people for résumés is rated more dangerous than one used by eighty for grammar. **Risk follows the data, not the popularity.**

Four screens, and one of them changes by itself.

Every screen answers one question and shows its evidence. No page asserts a conclusion without a clause behind it.

01 · DASHBOARD



02 · TOOL REGISTER

Tool register

sorted by risk

TOOL	USERS	RISK
● ChatGPT Résumés, payments	40	RED
● salesgpt.io Customer list	3	RED
● AI coding tool Source code	5	RED
● DeepL Contracts	9	RED
● Gemini Email, contracts	12	AMBER
● Grammarly Marketing copy	12	AMBER
● Otter.ai Meeting audio	7	AMBER
● Notion AI Internal notes	11	AMBER
● Copilot (biz) Internal docs	25	GREEN
● Zoom AI (ent) Meeting audio	18	GREEN
● Perplexity Research notes	6	RED
● QuillBot Client documents	4	RED
● Canva AI Brand assets	14	AMBER
● Miro AI Process maps	8	AMBER
● GitHub Copilot Source code	5	GREEN

8 more below · export as CSV or PDF

03 · EVIDENCE VIEW

Evidence view

ChatGPT free

● ChatGPT — free tier

RED

Q1 Trains on inputs?
Privacy §4.2

Yes
Confirmed

Q2 Can it be disabled?
Terms §2.1

Paid only
Confirmed

Q3 Retention
Privacy §6

30 days
Confirmed

Q4 Server location
Sub-processors

United States
Confirmed

Q5 DPA available?
Terms §7

Not this tier
Confirmed

Q6 Certification
Trust page

SOC 2 Type II
Confirmed

Q7 Shares with others?
no clause found

Not Verified

Q8 Deletion on request?
Privacy §8

Yes, 30 days
Confirmed

RECOMMENDATION

Restrict. Buy the Team plan for HR,
or prohibit for personal data.

VERIFICATION

7 of 8 confirmed by agent 3 · 1 not verified

Every answer stores its clause and read date.

04 · CHANGE ALERTS

Change alerts

Watcher · monthly

12 AUG · NOTION AI

GREEN → AMBER

Retention clause changed

Was: deleted within 30 days
Now: retained up to 12 months

09 AUG · SALESGPT.IO

NEW · RED

New tool — no policy found

Vendor and server location unknown.
3 users in Sales.

05 AUG · GRAMMARLY

Sub-processor list updated, no risk change

DRAFT AI USAGE POLICY

Generated 12 Aug · version 4
6 prohibited · 9 restricted · 8 approved
Ready for the security committee

EXPORT

NEXT SCHEDULED RUN

01 September 2026 · 03:00, automatic

Raised only when the wording actually changes.

The demonstration that matters: an agent detecting a real change in a vendor's terms between two runs, unprompted.

Screen 04 is the only one that can produce something nobody typed into it. If that works in the viva, the agentic claim is proven rather than argued.

Research first, build second, measure third.

PHASE 01

2 wks

Establish the problem is real

Rather than relying only on published literature, I will collect **primary data** through an anonymous survey of working professionals.

- Which AI tools they use at work
- Whether their employer has permitted it
- Whether an AI policy exists
- Whether they have submitted company data

Target: 40–60 valid responses. Anonymous, informed consent, no employer identifiers.

PHASE 02

7 wks

Build the prototype

One agent at a time, each tested in isolation before being connected to the next. Code is generated with an AI coding assistant under my direction.

- Agents 1 → 5, then the interface
- Synthetic access logs, documented
- Real, public vendor policy documents
- Scheduled job for the monthly loop

Declared openly: the design decisions, framework, scoring model and analysis are my own work.

PHASE 03

3 wks

Measure whether it works

I read the same source documents manually and compare. **20 tools × 8 questions = 160 findings** — the agreement rate becomes the quantitative result.

- Agreement rate against manual reading
- False-confidence rate — the metric that matters
- Proportion correctly marked Not Verified
- Practitioner feedback on usefulness

Accuracy is a finding, not a pass/fail. A measured weakness is still a result.



Deliberately simple tools.

Nothing here needs a GPU, a dataset or a server rack. The project runs on a laptop, which is why the risk of not finishing is low.

WEB APP

Next.js

One framework, interface and server

DATABASE

SQLite

A single file, nothing to install

AGENTS

Claude API

Tool use and multi-step reasoning

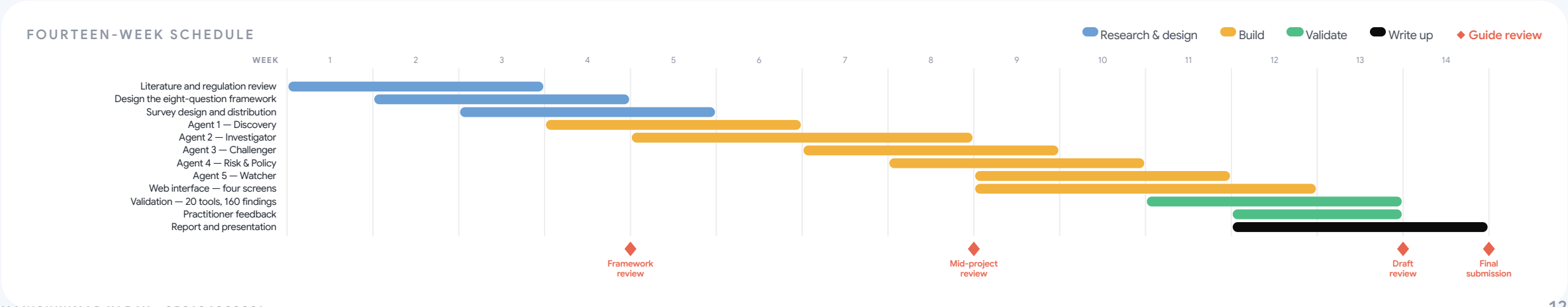
SCHEDULE

Cron job

Triggers the monthly Watcher run

EFFORT ESTIMATE	
Research & survey	2 weeks
Framework design	2 weeks
Build	7 weeks
Validation	2 weeks
Report & presentation	1 week
Total	14 weeks

If time runs short, Agent 5 is the designated cut — the remaining four still form a complete, demonstrable system.



Four deliverables, and the criteria I propose you judge them against.



Working web application

Five agents, four screens, demonstrable live on a laptop



Project report

Literature, survey findings, design, validation, conclusions



Primary survey data

Original evidence on unsanctioned AI use in India



Assessment framework

The eight-question model, usable without the software

EVALUATION CRITERIA

AI tools correctly identified from logs, including ones on no existing list ≥ 90%

Extracted answers agreeing with my own manual reading ≥ 85%

Confidently stated but wrong answers — *the failure mode that matters* < 5%

Watcher detects a genuine change between two runs demonstrated live

Survey responses collected ≥ 40

The third row is the one I would most like to be marked on. An AI system that is wrong *and* confident is worse than one that admits it does not know.



Boundaries, stated up front.

Establishing these now rather than being asked about them later. Two of them materially limit what the project can claim.

OBSERVED THROUGHOUT

- No real organisation's network, systems or logs are accessed. All usage data is **synthetic and generated by me**, with the method documented.
- No scanning, probing or intrusive testing of any third party. The agents read **publicly published documents only**.
- Survey participation is voluntary and anonymous, with informed consent and no employer identifiers.
- The tool reports a documented position and gaps. **It does not certify legal compliance**, and the interface will state that.

ACKNOWLEDGED LIMITATIONS

- The prototype runs on **synthetic logs**. Deployment in a live organisation is out of scope for a minor project.
- The agents read **published policy only**. What a vendor does internally cannot be verified from outside.
- Findings are accurate **as at the date read** — which is precisely why Agent 5 exists.
- Encoding legal text into software carries responsibility; I will ask the cyber-law faculty to sanity-check the rules engine.

GUIDANCE I WOULD VALUE

Three questions I would rather settle with you before week one than discover in week nine.

- Is the eight-question framework the right depth, or should it be expanded?
- Is a survey sample of 40–60 adequate for the report's requirements?
- Should scope be reduced to four agents to lower delivery risk?

A management problem with a software instrument.

Governance, risk & compliance

Asset inventory, third-party risk assessment, policy formulation, continuous control monitoring.

Data protection law

DPDP Act 2023, GDPR transfer principles, EU AI Act transparency duties, ISO/IEC 42001.

Emerging technology management

Controlled adoption of generative AI — the governance side, not the engineering side.

Research methods

Primary survey design, sampling, framework construction, measured validation against a manual baseline.

WHY THE TOPIC IS WORTH DOING NOW

Firewalls, antivirus and phishing are thoroughly studied subjects. Unsanctioned AI usage is roughly two years old, has almost no tooling for mid-sized organisations, and sits at the exact point where **management, law and technology meet** — which is the intersection this programme is about.

THE CONTRIBUTION CLAIMED

- An eight-attribute framework for assessing an AI vendor
- A working multi-agent implementation that finds unlisted tools
- An adversarial verification design that permits “I don't know”
- Primary evidence on prevalence among Indian professionals



Organisations cannot govern AI usage they cannot see.

This project builds the thing that makes it visible — and it is honest about the limits of what a five-day agent run can prove.

I am seeking approval to proceed with this topic, and would welcome guidance on the three questions on slide 14.

14 WEEKS

5 AGENTS

WORKING PROTOTYPE + REPORT

Student	Manishkumar Yadav
Enrolment number	250104002031
Programme	MBA — Cyber Security Management
Semester	III
School	School of Management Studies
University	NFSU, Gandhinagar